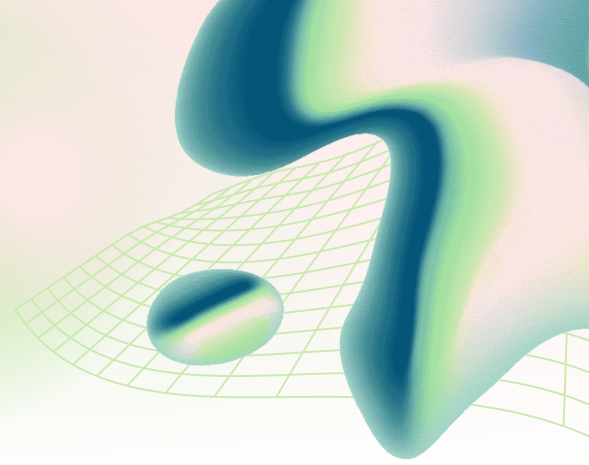


# VULNERABILITY ASSESSMENT REPORT

<http://testfire.net>  
(Altoro Mutual Demo Application)



## EXECUTIVE SUMMARY

Passive security assessment conducted against testfire.net using non-intrusive techniques. Focus on exposed services, HTTP response headers, client-side security controls, cookie security, and publicly disclosed information. No exploitation, authentication bypass, brute force, DOS, or active attacks performed.

### Risk Overview:

- **High:** 0
- **Medium:** 7
- **Low:** 10+
- **Informational:** Multiple

## ASSESSMENT METHODOLOGY

### Scope Included:

Publicly accessible pages, HTTP/HTTPS configuration review, Header analysis, Cookie inspection, Passive vulnerability scanning, Service exposure review

### Scope Excluded:

Authentication attacks, Login bypass attempts, Exploitation of vulnerabilities, Brute-force attacks, Denial-of-Service testing, Any activity that could impact availability

## TOOLS USED

| Tool                     | Purpose                                  |
|--------------------------|------------------------------------------|
| Nmap                     | Port and service identification          |
| OWASP ZAP (Passive Scan) | Passive vulnerability discovery          |
| browser Developer Tools  | Header, cookie, and client-side analysis |

## ASSET IDENTIFICATION

- **Domain:** testfire.net
- **IP Address:** 65.61.137.117

## SERVICE EXPOSURE REVIEW

### Open Ports:

| Port     | Service        | Details              |
|----------|----------------|----------------------|
| 80/tcp   | HTTP           | Apache Tomcat/Coyote |
| 443/tcp  | HTTPS          | Apache Tomcat/Coyote |
| 8080/tcp | HTTP Alternate | Apache Tomcat/Coyote |

**Observation:** Application exposes both encrypted and unencrypted services

**Risk:** Traffic interception, Session hijacking, Downgrade attacks, Accidental transmission of credentials over cleartext

**Severity:** MEDIUM

**Recommendation:** Force HTTPS across entire application, Redirect all HTTP traffic to HTTPS, Disable unnecessary services and ports

```
ovosi@kali: ~  
(ovosi@kali)-[~]  
$ nmap -A -sC -sV -p- testfire.net -vv  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-12 12:05 +0100  
NSE: Loaded 158 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 12:06  
Completed NSE at 12:06, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 12:06  
Completed NSE at 12:06, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 12:06  
Completed NSE at 12:06, 0.00s elapsed  
Initiating Parallel DNS resolution of 1 host. at 12:06  
Completed Parallel DNS resolution of 1 host. at 12:06, 0.01s elapsed  
Initiating Ping Scan at 12:06  
Scanning testfire.net (65.61.137.117) [4 ports]  
Completed Ping Scan at 12:06, 0.03s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 12:06  
Completed Parallel DNS resolution of 1 host. at 12:06, 0.50s elapsed  
Initiating SYN Stealth Scan at 12:06  
Scanning testfire.net (65.61.137.117) [65535 ports]  
Discovered open port 8080/tcp on 65.61.137.117  
Discovered open port 443/tcp on 65.61.137.117  
Discovered open port 80/tcp on 65.61.137.117  
Discovered open port 8080/tcp on 65.61.137.117  
Discovered open port 80/tcp on 65.61.137.117  
Discovered open port 443/tcp on 65.61.137.117  
SYN Stealth Scan Timing: About 4.77% done; ETC: 12:16 (0:10:19 remaining)  
SYN Stealth Scan Timing: About 15.99% done; ETC: 12:12 (0:05:21 remaining)  
SYN Stealth Scan Timing: About 25.97% done; ETC: 12:11 (0:04:19 remaining)  
SYN Stealth Scan Timing: About 36.88% done; ETC: 12:11 (0:03:27 remaining)
```

```
ovosi@kali: ~  
PORT      STATE SERVICE REASON          VERSION  
80/tcp    open  http    syn-ack ttl 128 Apache Tomcat/Coyote JSP engine 1.1  
|_http-server-header: Apache-Coyote/1.1  
443/tcp   open  ssl/http syn-ack ttl 128 Apache Tomcat/Coyote JSP engine 1.1  
|_ssl-date: 2026-06-12T11:12:46+00:00; 0s from scanner time.  
|_ssl-cert: Subject: commonName=demo.testfire.net  
| Subject Alternative Name: DNS:demo.testfire.net  
| Issuer: commonName=Sectigo RSA Domain Validation Secure Server CA/organizationName=Sectigo Limited/stateOrProvinceName=Greater Manchester/countryName=GB/localityName=Salford  
| Public Key type: rsa  
| Public Key bits: 2048  
| Signature Algorithm: sha256WithRSAEncryption  
| Not valid before: 2025-05-21T00:00:00  
| Not valid after: 2026-06-21T23:59:59  
| MD5: 04a1 2772 0069 3d65 011d ded8 ccb0 201c  
| SHA-1: a1e9 8d60 388b 84f4 bbc5 50d7 b61b b2b0 cc89 61fd  
| SHA-256: b0ea c225 501d b594 a963 9f9e 718b c036 759b 9f49 2c7c 729a 60c8 4735 6839 3382  
| -----BEGIN CERTIFICATE-----  
| MIIGLDCBRsGAWIBAgIQCFc26PmXdevJdonrg/txbTANBgkqhkiG9w0BAQsFADCB  
| jzELMAkGA1UEBhMCRC0IxGzAZBgNVBAgTEkdyZWZ0ZXIgtWfuV2hlc3RlcjEQMA4G  
| A1UEBxMMHU2FzZm9yZDEYMBYGA1UEChMPU2VjdGlnbyBMaW1pdGVkMTcwNQYDVQQD  
| Ey5TZWN0aWdvIFJTSBEB21haW4gVmFsaWRhdGlvbiBTZW51cmUgU2VydMvVyIENB  
| MB4XDTI1MDUyMTAwMDAwMFOxDTI2MDYyMTIzNTk1OVowHDEaMBGGA1UEAxMRZGVt  
| by50ZXN0ZmlyZS5uZXQwggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQC  
| 7mJPxc2MMpWbIgFA2g8r91LVX52B4Ir9I4KYLXhFC89+baLgaIilMuRmzrF2P55y  
| zSLJHA57URJ8Hx00wlljwbkCk3T/UqUiY0/ksQz4pzHa+B05M26tDZtB4Fg85Sin  
| iyp1Dh6A7052zwSQ4YU165Nb6K1hA0SL+m63/kLKWwIDZUS8phZE+IKcZzsB08  
| XLQVf6zNtGg1/1GTPEJLOGdriRd9QNnfku3kyRSmTex92mGYxfGLvATLLY+botR  
| G+b8Yi3NibLDs34Y430y463TzFwmvD2nRZQyb10Xpaj0y4x/K6p59i3AesZ4FITD  
| /tLDAN6e4DrKQ8aPjtBLAGMBAAGjggL0MIIC8DAFBGNVHSMEGDAWgBSNjF7EVK2K  
| 4Xfpm/mbBeG4AY1h4TadBgNVHQ4EFgQUd+bm67/wg0329JuDKpo8icXfEewwDgYD  
| VR0PAQH/BAQDAgWgMAwGA1UdEwEB/wQCMAAwHQYDVR0LBBYwFAyIKwYBBQUHAWEG  
| CCSGAQFUBwMCMekGA1UdIARCMCAwNAYLKwYBBAGyMQECAgcwJTAjBggrBgEFBQcC
```

```
ovosi@kali: ~  
| zSLJHA57URJ8Hx00wlljwbkCk3T/UqUiY0/ksQz4pzHa+B05M26tDZtB4Fg85Sin  
| iyp1Dh6A7052zwSQ4YU165Nb6K1hA0SLe+m63/kLKWwcIDZUS8phZE+IKcZzsB08  
| XLQVf6zNtGg1/1GTPEJLOGdrIRd9QnNfkU3kyRSmTex92mGYxfGLvATLLY+botR  
| G+b8Yi3N1bLds34Y430y463TzFwmvD2nRZQyb10XpaJ0y4x/K6p59i3AesZ4FITD  
| /tLDAN6e4DrKQ8aPjtBLAGMBAAGjggL0MIIC8DAfBgNVHSMEGDAWgBSNjF7EVK2K  
| 4Xfpm/mbBeG4AY1h4TAdBgNVHQ4EFgQUUD+bm67/wg0329JuDKpo8icXfEewwDgYD  
| VR0PAQH/BAQDAgWgMAwGA1UdEwEB/wQCAAAwHQYDVROlBBYwFAYIKwYBBQUHAWEG  
| CCsGAQUFBwMCMCEkGA1UdIARCMCAwNAYLKwYBBAGyMQECAgcwJTAjBggrBgEFBQcC  
| ARYXaHR0CHM6Ly9zZWNoaWdvLmNvbS9DUFMwCAYGZ4EMAQIBMIIGBggrBgEFBQcC  
| AQR4MHYwTwYIKwYBBQUHMAKGQ2h0dHA6Ly9jcncUc2VjdGlnby5jb20vU2VjdGln  
| b1JTQRvbwFpblZhbGkYXRpb25TZWN1cmVTZXJ2ZXJ0Q55jcnQwIwYIKwYBBQUH  
| MAGGF2h0dHA6Ly9vY3NwLnNlY3RpZ28uY29tMIIBfwYKKwYBBAHwEIEAgSCAW8E  
| ggFrAwkAdwCLW2S/VViXrfdH2g3CEJ36fA61fak8ZuRqQ/D8qpxgAAAZbzE8bg  
| AAEEAwBIMEYICQYhdWq5m8sBYpW58ItIC4Fyr3jcAeJVHj+SvEX3mapwIhAPfb  
| XiyMcy9/ysVWIsY0U4dfBvcECLJJOcUwBCNY0AHYAGYbUxyiqb/66A294Kk0B  
| kar0LXIxD670XXBBLsVMx9QAAAGW8xPGiAABAMARzBFA1A3Xh4AYvc99nmX0tS  
| Ms2S1VbHwg7g0zWGFJ1kRh1UQIhAIpaL10o+CU4qh3varw/LQ0EYk8scAbq07GA  
| UbYw37+AAHYAD1eUvPOuqT4zGyyZB7P3kN+bwj1xMiXdIaklrGHFTiEAAAGW8xPG  
| igAABAMARzBFAiB0fQUPhhd9pi8T0/96VAfVmuS8l7LAQXr3hXhZQuCAIhAIX2  
| g17jbpsnWTP4ImDmzuVAKDqzPMU18qcs7U7Izt1BMBwGA1UdEQQVMBOCEWRlBw8u  
| dGVzdGZpcUubmV0MA0GCSqGSIb3DQEBCwUAA4IBAQAcs7hS4Cg/m4LwdTjwydMl  
| o9bPEpcKxJcL6LMB06eK3qSKp0cVDSWLBFRFAM9PaxjKTzKuTBjExN1oYaTj2XN6  
| Z+qwkPgjS4gVuKV2bw1r9VjnL6KMcmQ+/Tp5D83duJG7hZjw+E6HjV1Ml0jdJmGN  
| SgxtYv6lra4PNYA5zMTFYB7r7ijLPANp7mwFp0hcF9B+1w03g05J7PTRKME09GjA6  
| 3DEaVHRDH6onmoEDCfiCHFrLlr6xctw44EbY9HDVw2mM8GfCkgrfQuEJjQW0JEpP  
| +caySon48gkx/FjOwrZEdxPajGZ7TTJgYYOZzDUorWfuZEbzFRtlQ7iWVlnHfK9  
| _____END CERTIFICATE_____
```

```
8080/tcp open  http      syn-ack ttl 128 Apache Tomcat/Coyote JSP engine 1.1  
|_http-server-header: Apache-Coyote/1.1  
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port  
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete  
Aggressive OS guesses: Actiontec MI424WR-GEN3I WAP (97%), DD-WRT v24-sp2 (Linux 2.4.37) (97%), Microsoft Windows XP SP3 or Windows 7 or Windo  
ws Server 2012 (97%), Linux 3.2 (95%), Microsoft Windows XP SP3 (95%), VMware Player virtual NAT device (95%), Linux 4.4 (92%), BlueArc Titan
```

## WEB SERVER INFORMATION DISCLOSURE

Server header reveals: Apache-Coyote/1.1

Technology fingerprinting identified: Apache Tomcat, Java, React, Swagger UI, Nginx, AWS-related services

**Impact:** Public disclosure assists attackers in identifying known vulnerabilities, targeting outdated software, building attack paths

**Severity:** LOW

**Recommendation:** Configure server to suppress version disclosure



Content-Security-Policy:

default-src 'self';

script-src 'self';

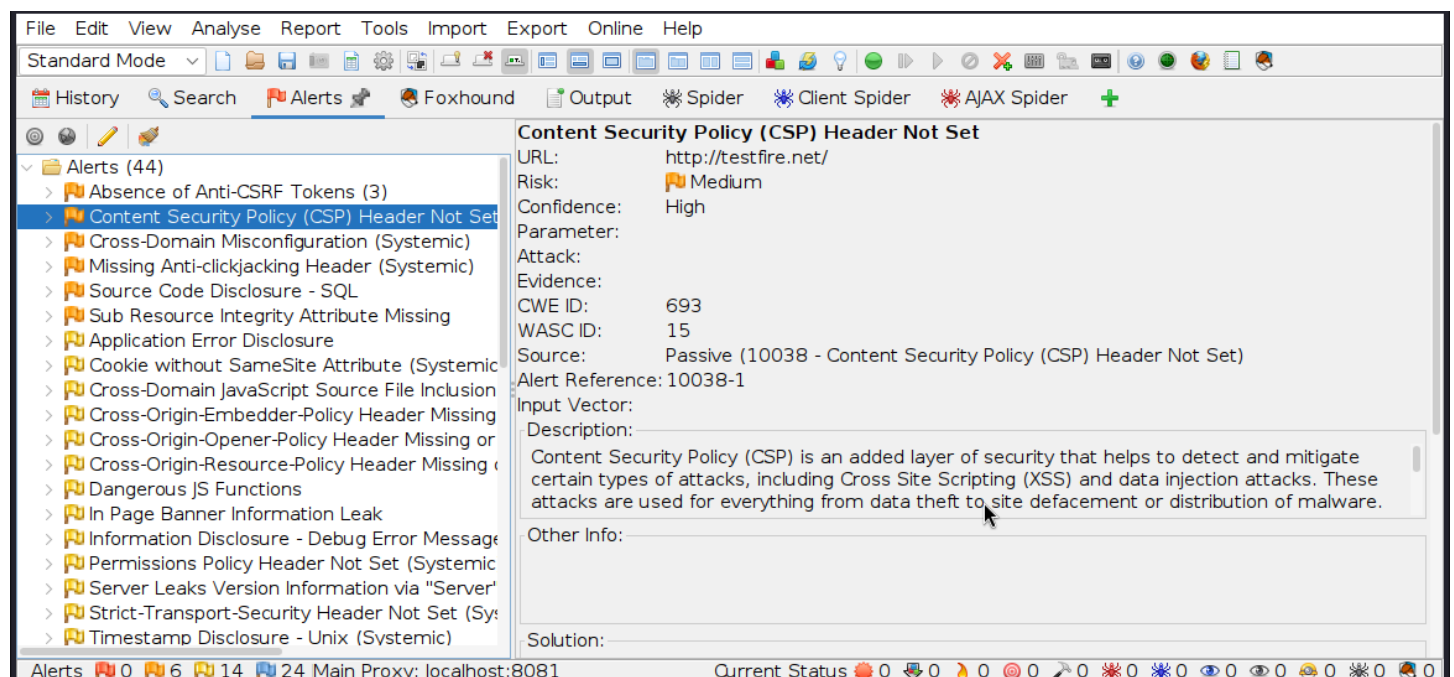
style-src 'self';

img-src 'self' data;;

object-src 'none';

frame-ancestors 'none';

base-uri 'self';



## FINDING 2 - CLICKJACKING PROTECTION MISSING

**Evidence:** Missing Anti-clickjacking Header

### Summary

The HTTP X-Frame-Options response header can be used to indicate whether a browser should be allowed to render the document in a <frame>, <iframe>, <embed> or <object>. Sites can use this to avoid clickjacking attacks and some cross-site leaks, by ensuring that their content is not embedded into other sites.

**Impact:** Attackers may embed pages within invisible frames and trick users into clicking unintended actions



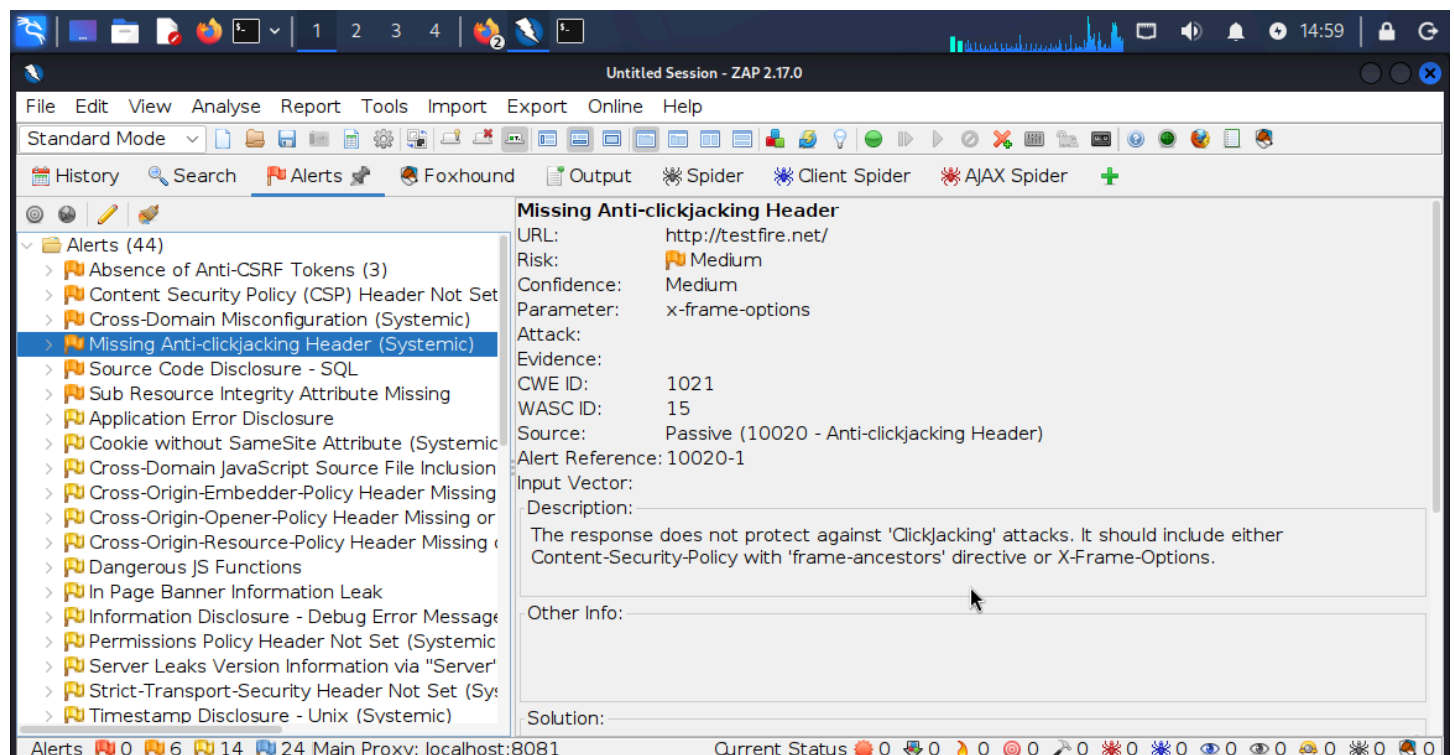
**Severity:** MEDIUM

**Recommendation:** Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

**Example:**

X-Frame-Options: DENY

X-Frame-Options: SAMEORIGIN



## FINDING 3 - SUB RESOURCE INTEGRITY ATTRIBUTE MISSING

### Summary

Subresource Integrity (SRI) is a security feature that enables browsers to verify that resources they fetch (for example, from a Content Delivery Network{CDN}) are delivered without unexpected manipulation. It works by allowing you to provide a cryptographic hash that a fetched resource must match.

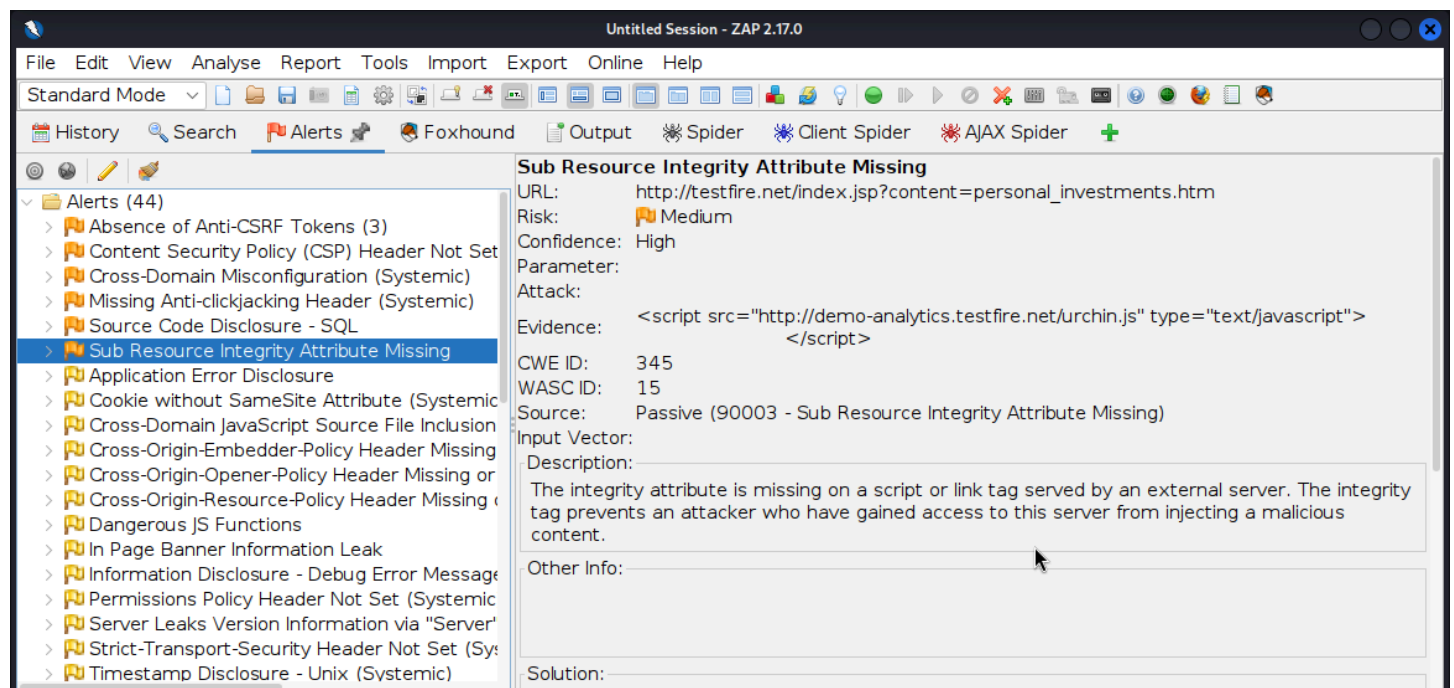
**Impact:** An attacker who compromises the third-party content provider or delivery infrastructure could inject malicious code into the external resource. This may result in client-side code execution, theft of sensitive information, session hijacking, or phishing attacks against application users.

**Severity:** medium

**Recommendation:** Implement SRI by adding the integrity attribute and appropriate crossorigin settings to all externally hosted scripts and stylesheets. Periodically review third-party dependencies and host critical resources locally where feasible.

**Example:**

```
<script  
  
  src="https://demo-analytics.testfire.net/urchin.js"  
  
  type="text/javascript"  
  
  integrity="sha384-oqVuAfXRKap7fdgcCY5uykM6+R9GqQ8K/ux..."  
  
  crossorigin="anonymous">  
</script>
```



## FINDING 4 - CROSS-ORIGIN SECURITY HEADERS MISSING

**Summary:** Cross-origin security headers help protect web applications from attacks involving untrusted origins, cross-origin resource sharing, and browser process isolation. Common headers



include:

- Cross-Origin-Opener-Policy (COOP)
- Cross-Origin-Embedder-Policy (COEP)
- Cross-Origin-Resource-Policy (CORP)

When these headers are missing, the browser applies less restrictive default behavior, potentially exposing users and applications to cross-origin attacks and information leakage.

**Impact:** An attacker may leverage browser cross-origin behaviors to gather information about authenticated users, application states, or loaded resources. The absence of these headers also reduces browser isolation mechanisms designed to mitigate modern web-based attacks such as XS-Leaks(cross-site leaks) and related cross-origin exploitation techniques.

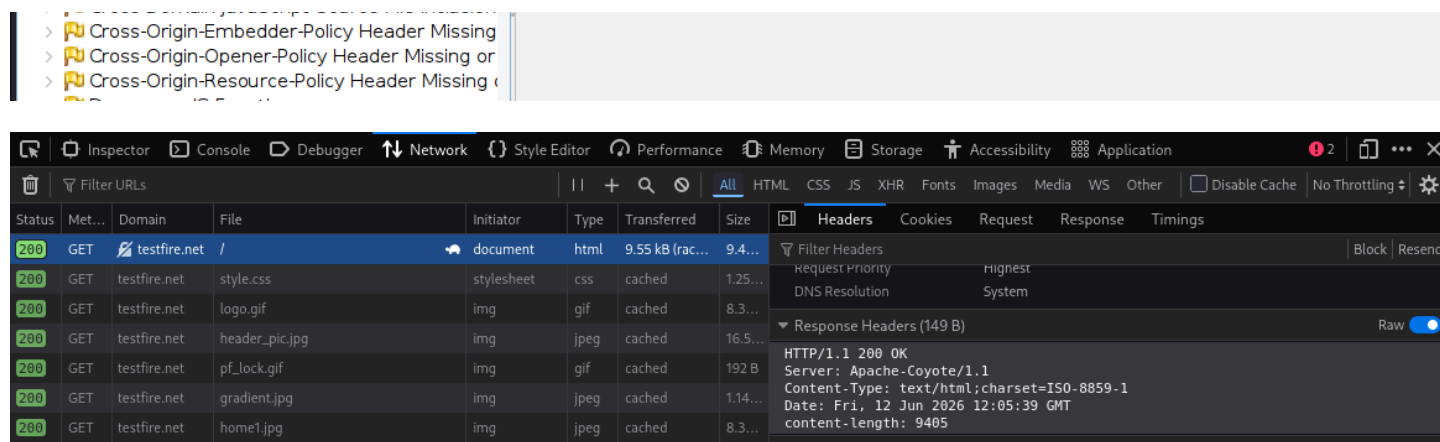
**Severity:** LOW

**Recommendation:** Implement appropriate cross-origin security headers based on application requirements:

Cross-Origin-Opener-Policy: same-origin

Cross-Origin-Embedder-Policy: require-corp

Cross-Origin-Resource-Policy: same-origin



## FINDING 4 - SESSION COOKIE SECURITY WEAKNESS

**Summary:** Session cookies are used to maintain a user's authenticated session with a web application. If session cookies are not configured securely, attackers may be able to steal, intercept, or misuse them to gain unauthorized access to user accounts.

Common session cookie security weaknesses include:

- Missing HttpOnly attribute

- Missing Secure attribute
- Missing SameSite attribute
- Predictable or weak session identifiers
- Excessive cookie lifetime

**Impact:** An attacker who obtains or abuses a valid session cookie may be able to impersonate legitimate users, resulting in unauthorized access to application functionality and sensitive information. Missing cookie security controls may also increase the impact of XSS and CSRF attacks.

**Risks:** Session hijacking, Credential theft, Man-in-the-middle exposure

**Severity:** MEDIUM

**Recommendation:** configure all session cookies with appropriate security attribute

Set-Cookie:

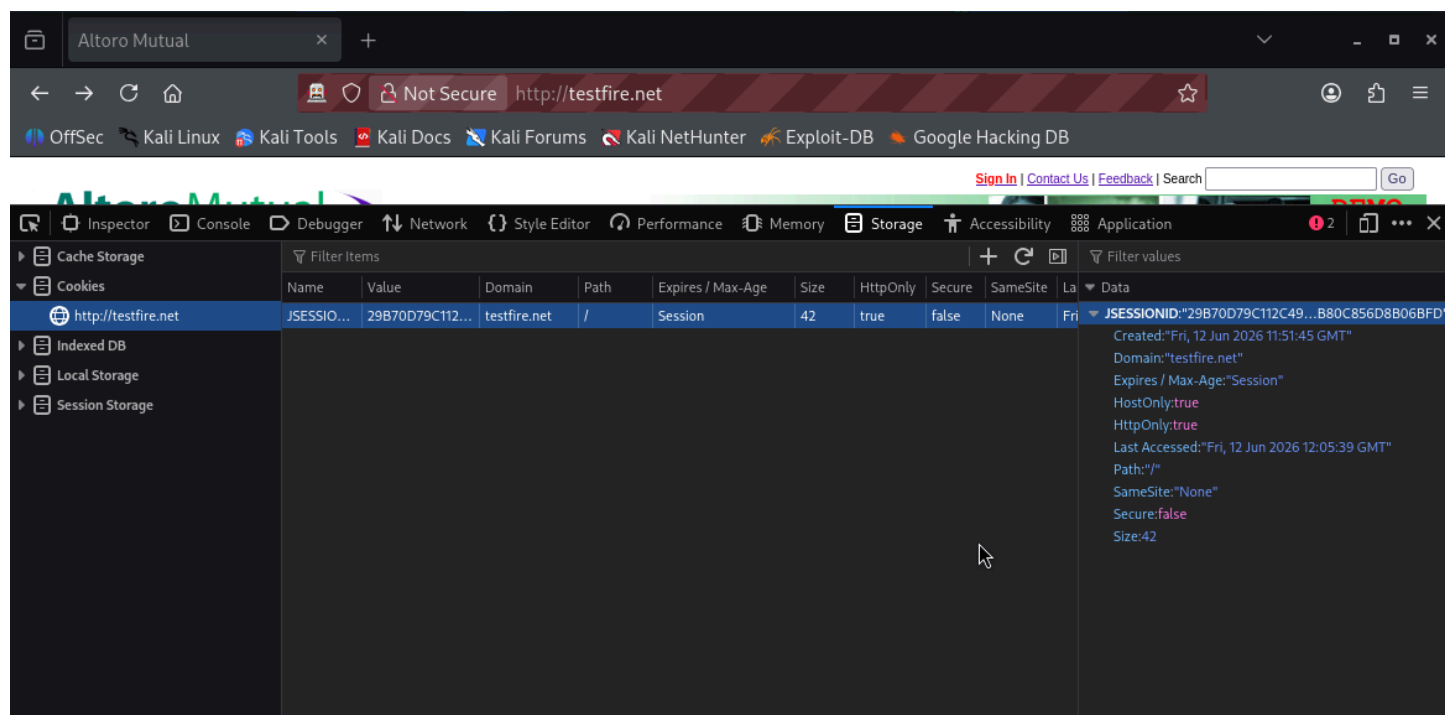
JSESSIONID=<random-session-id>;

HttpOnly;

Secure;

SameSite=Strict;

Path=



## FINDING 5 - INFORMATION DISCLOSURE THROUGH COMMENTS

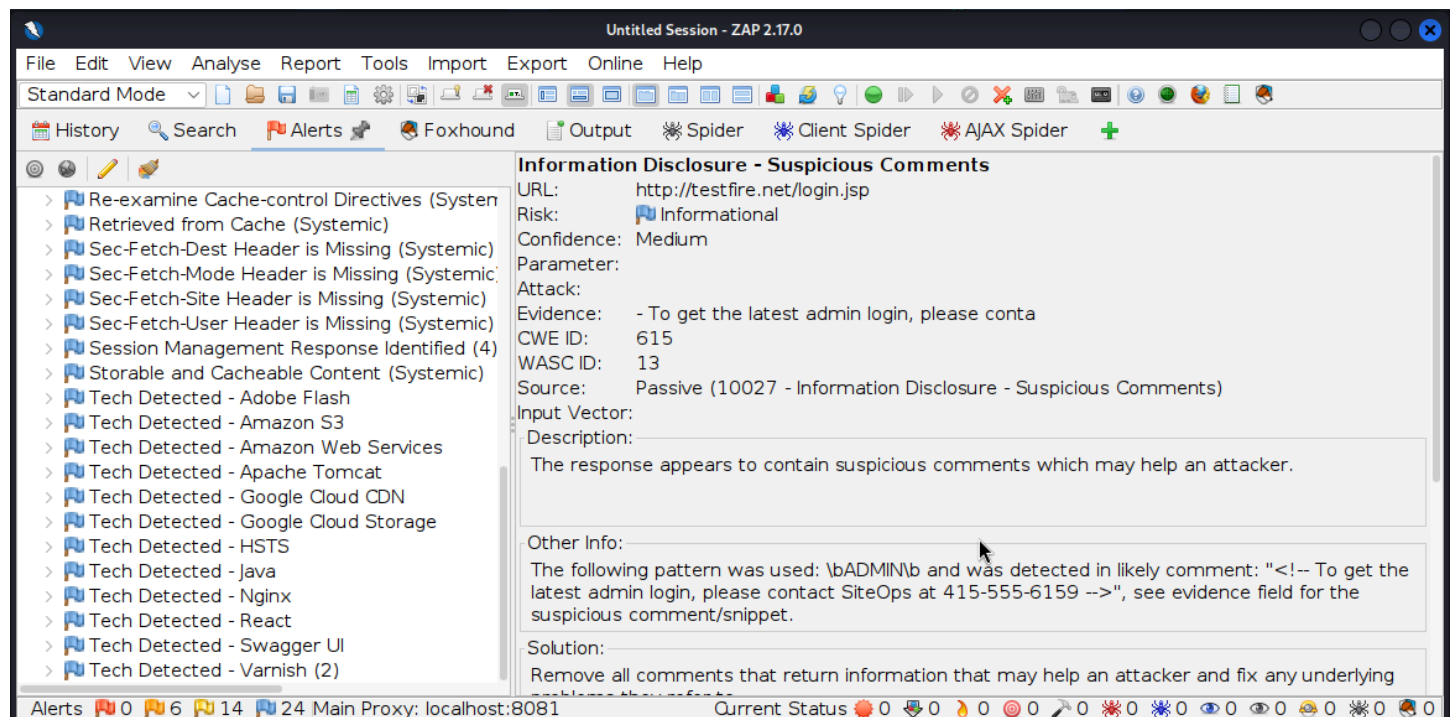
**Summary:** The response appears to contain suspicious comments which may help an attacker.

**Evidence:** OWASP ZAP identified suspicious HTML comments. Example: The following pattern was used `\bADMIN\b` and was detected in likely comment: "`<!-- To get latest admin login.`"

**Impact:** Comments may reveal administrative details, internal processes, developer notes, infrastructure information

**Severity:** LOW

**Recommendation:** Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.



## FINDING 6 - MISSING ANTI-CSRF PROTECTION

**Summary:** Cross-Site Request Forgery (CSRF) is an attack that tricks an authenticated user into performing unintended actions on a web application where they are currently logged in.

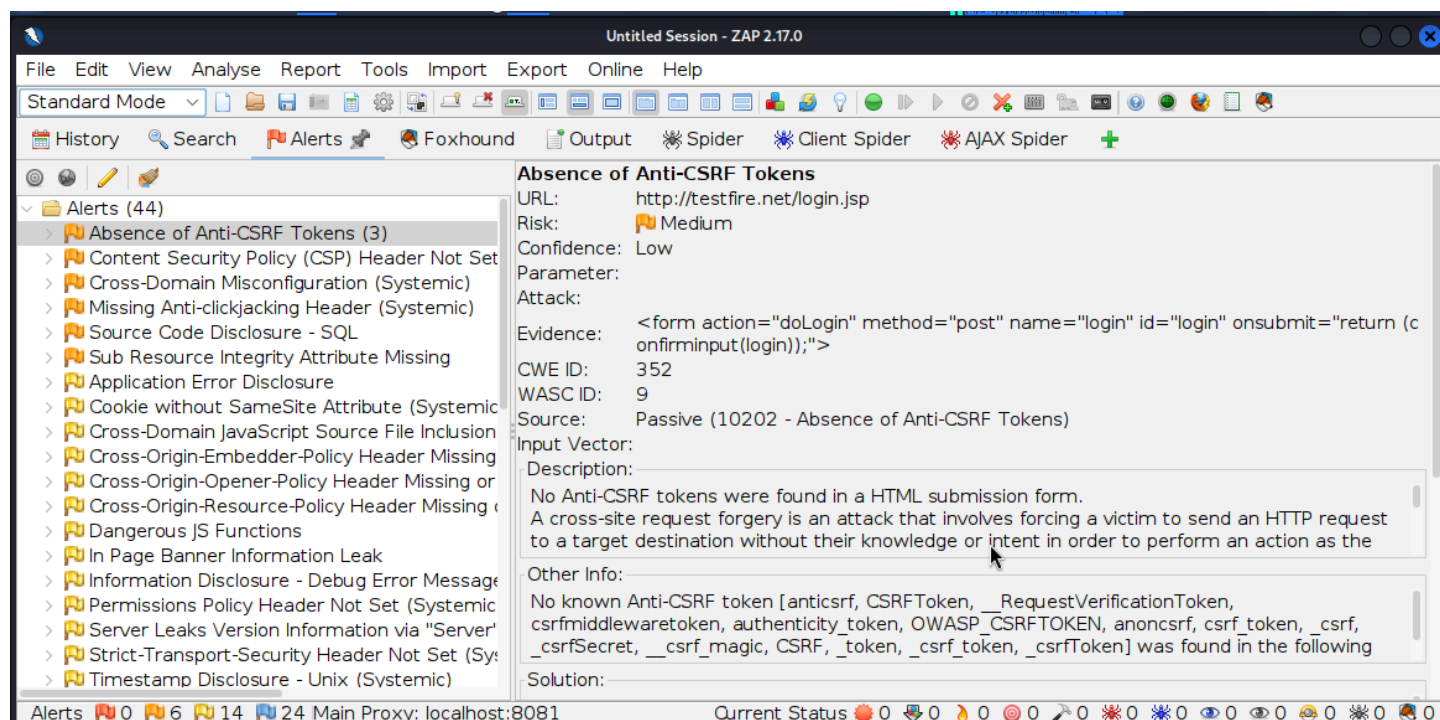
When anti-CSRF protections are missing, the application may accept state-changing requests (such as password changes, profile updates, money transfers, or account modifications) without verifying that the request originated from a legitimate user action.

**Evidence:** Absence of Anti-CSRF Tokens detected on multiple application functions

**Impact:** Attacker may trick authenticated user into submitting unwanted requests

**Severity:** MEDIUM

**Recommendation:** Implement synchronizer tokens, CSRF validation middleware, and cookie protections



## FINDING 7 - STRICT TRANSPORT SECURITY MISSING

**Summary:** Strict-Transport-Security (HSTS) **Missing** means the website is not instructing browsers to always use HTTPS when connecting to it.

**Evidence:** Header Not Set

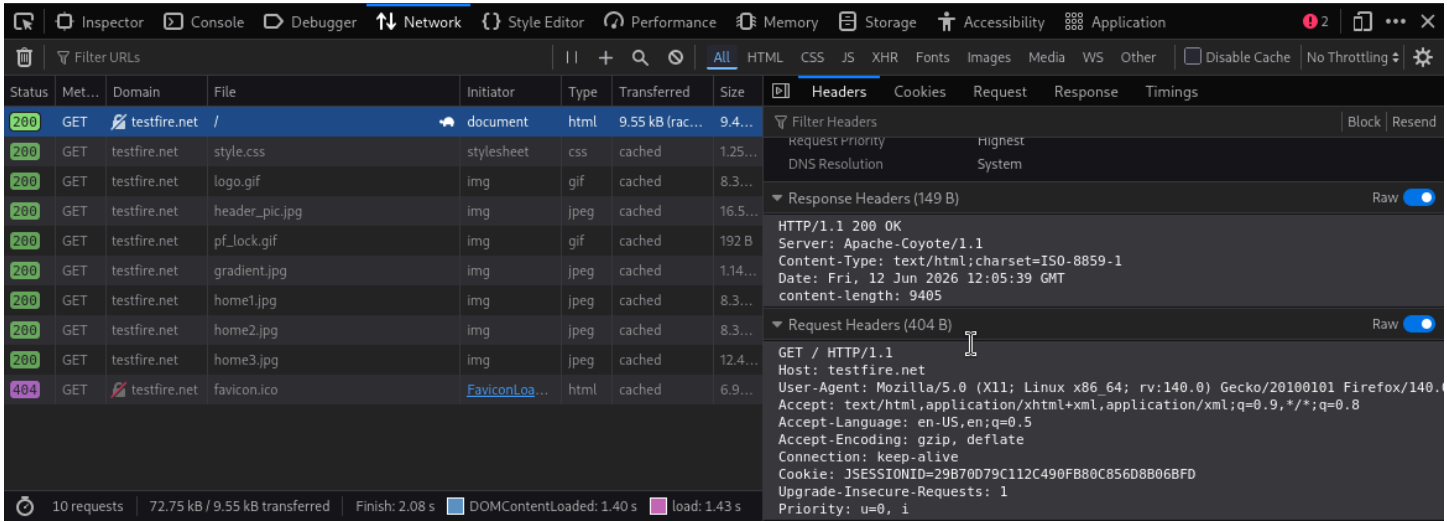
**Impact:** Users may initially connect through HTTP. Enables SSL stripping, downgrade attacks, session interception

**Severity:** MEDIUM

**Recommendation:** Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security. Add the HSTS header on all HTTPS responses.

**Example:** Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

> Strict-Transport-Security Header Not Set (Sys



# SECURITY MISCONFIGURATION SUMMARY

| Misconfiguration                         | Severity |
|------------------------------------------|----------|
| HTTP Service Exposed                     | Medium   |
| Missing CSP                              | Medium   |
| Missing Anti-Clickjacking Protection     | Medium   |
| Missing HSTS                             | Medium   |
| Session Cookie Missing Secure Flag       | Medium   |
| Missing CSRF Protection                  | Medium   |
| Missing sub resource integrity attribute | Medium   |
| Missing CO security headers              | Low      |
| Server Version Disclosure                | Low      |
| Information Disclosure via Comments      | Low      |
| Missing Cross-Origin Security Headers    | Low      |

# POSITIVE SECURITY CONTROLS OBSERVED

| Control                 | Status |
|-------------------------|--------|
| HttpOnly Session Cookie | Yes    |

# BUSINESS IMPACT SUMMARY

Identified issues are primarily configuration and hardening weaknesses rather than confirmed exploitable vulnerabilities. However, if left unresolved, they could assist attackers in harvesting information about environment, hijacking sessions, conducting phishing or clickjacking attacks, exploiting client-side vulnerabilities, Bypassing browser security controls. No critical or actively exploitable vulnerability was confirmed during this passive assessment.

# CONCLUSION

Application demonstrates functional HTTPS deployment and generally accessible service configuration. However, several industry-standard security controls are either missing or improperly configured, particularly regarding browser security headers, session cookie protection, and information disclosure. Addressing medium-risk findings should be prioritized to improve overall security posture and reduce exposure to common web-based attacks.

# DISCLAIMER

This assessment was conducted using passive and non-destructive techniques only. Findings are based on observations made during assessment period and do not constitute proof of exploitability. No actions were taken that could impact confidentiality, integrity, or availability of target system.